

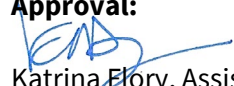


DAS Policy

No:
2100-21

System and Communications Protection

Effective:
March 5, 2024

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

This policy establishes the system and communications protection requirements for managing risks and establishes a system and communications protection program. The system and communications protection program helps DAS implement security controls with regard to system configuration and data communication and transfer.

The first occurrence of the word in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV. In addition, references to National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, “Security and Privacy Controls for Federal Information Systems and Organizations,” family identifiers and control numbers are provided in parentheses next to requirement headers, where applicable.

II. Scope

The scope of this policy covers any ***DAS-Managed System Assets***, including system assets managed by external service partners.

III. Policy

The following system and communications protection controls shall be applied to DAS-Managed System Assets, including those managed by external service partners:

- A. **Application Partitioning (SC-2)**: The information system shall separate user functionality from ***Information System Management Functionality***. The separation can be either physical or logical, and implemented by using different computers, different central processing units, different instances of operating systems, different network addresses, different web interfaces, virtualization techniques, or combinations of these or other methods, as appropriate.

- B. **Information in Shared Resources (SC-4)**: The information system shall prevent unauthorized and unintended information transfers via shared system resources. This control is commonly referred to as object reuse and residual information protection. Information, including encrypted information, of previous users, roles, or processes in shared systems resources (e.g., registers, main memory, hard disks) is prevented from being available to any current users, roles, or processes after those resources have been released back to the information system.
- C. **Denial of Service Protection (SC-5)**: The information system shall be protected against or able to limit the effects of **Denial of Service (DoS)**, including **Distributed Denial of Service (DDoS)**, attacks. For example, **Boundary Protection Devices** can filter certain types of packets to safeguard information systems on internal networks from DoS and DDoS attacks.
- D. **Boundary Protection (SC-7)**: The information system shall:
1. Monitor and control communications at the external boundary of the system and at key internal boundaries within the system.
 2. Implement subnetworks for publicly accessible systems that are physically or logically separated from internal networks. Subnetworks that are physically or logically separated from internal networks are referred to as demilitarized zones (DMZs).
 3. Connect to external networks or information systems only through managed interfaces consisting of Boundary Protection Devices (e.g. **Routers, Gateways, Firewalls**) based on a security architecture.
 4. Limit the number of external network connections. Limiting the number of external network connections facilitates monitoring of inbound and outbound communications traffic.
 5. Each external telecommunication service shall have a managed interface with a traffic flow policy to protect the **Confidentiality** and **Integrity** of the information being transmitted.
 6. At managed interfaces deny network communications traffic by default and allow network communications traffic by exception. A deny all and permit by exception network communications traffic policy ensures that only those connections which are essential and approved are allowed.
 7. The information system, in conjunction with a remote device, shall prevent the device from simultaneously establishing non-remote connections with the system and communicating via some other connection to resources in external networks. VPNs shall be considered non-remote connections and **Split Tunneling** is prohibited.

- E. **Transmission Confidentiality and Integrity (SC-8)**: The information system shall protect the Confidentiality and Integrity of transmitted information. This can be accomplished by physical means (e.g., employing **Protected Distribution Systems**) or by logical means (e.g., employing encryption techniques).”
- F. **Cryptographic or Alternate Physical Protection**: The information system shall implement cryptographic mechanisms to prevent unauthorized disclosure of information and detect changes to information during transmission unless protected by alternate physical safeguards.
- G. **Network Disconnect (SC-10)**: The information system shall terminate the network connection associated with a communications session at the end of the session or after 30 minutes of inactivity. This control applies to both internal and external network connections.
- H. **Cryptographic Key Establishment and Management (SC-12)**: Cryptographic key management and establishment shall be performed using manual procedures or automated mechanisms with supporting manual procedures. **Trust Stores** are to be managed to ensure that only approved **Trust Anchors** are in such Trust Stores. This includes certificates with visibility external to the information systems and certificates related to the internal operations of systems.
- I. **Cryptographic Protection (SC-13)**: The information system shall implement cryptographic protection in accordance with Ohio IT Standard ITS-SEC-01, “Data Encryption and Cryptography,” and with applicable federal and state laws, executive orders/directives, regulations, policies, and standards.
- J. **Collaborative Computing Devices (SC-15)**: The information system shall prohibit remote activation of collaborative computing devices (e.g., networked white boards, cameras, and microphones), and provide explicit indication of use, (e.g., signals to users when collaborative computing devices are activated) to users physically present at the devices.
- K. **Public Key Infrastructure Certificates (SC-17)**: Public Key Infrastructure certificates shall be issued by the DAS certificate authority (CA) or obtained from an approved service provider.
- L. **Active Content and Mobile Code (SC-18)**: DAS-managed information systems shall only deploy active content and Mobile Code in accordance with the requirements outlined in DAS Standard DAS-ITS-2100-21-A, “Secure Active Content and Mobile Code.”

DAS OISP shall establish usage restrictions and implementation guidance for acceptable Mobile Code and Mobile Code technologies, and authorize, monitor, and control the use of Mobile Code within the information system. Decisions regarding the use of Mobile Code within

the information system are based on the potential to cause damage to the system if used maliciously.

- M. **Voice over Internet Protocol (SC-19)**: DAS OIT shall establish usage restrictions and implementation guidance for Voice over Internet Protocol (VoIP) technologies and authorize, monitor, and control the use of VoIP within the information system. Decisions regarding the use of VoIP within the information system are based on the potential to cause damage to the system if used maliciously.
- N. **Secure Name and Address Resolution Service (SC-20 and SC-21)**: The information system shall:
1. Provide additional data origin authentication and Integrity verification artifacts along with the authoritative name resolution data the system returns in response to external name and address resolution queries;
 2. Provide the means to indicate the security status of child zones (if the child supports secure resolution services) and to enable verification of a chain of trust among parent and child domains, when operating as part of a distributed, hierarchical namespace; and
 3. Request and perform data origin authentication and data Integrity verification on the name and address resolution responses the system receives from authoritative sources.
- O. **Architecture and Provisioning for Name and Address Resolution Service (SC-22)**: The information system that collectively provides the name and address resolution service shall be fault-tolerant and implement internal and external role separation. To eliminate single points of failure and enhance redundancy, employ at least two authoritative domain name system servers, one configured as the primary server and the other configured as the secondary server. For role separation, DNS servers with internal roles shall only process name and address resolution information requests from internal clients and DNS servers with external roles from external clients.
- P. **Session Authenticity (SC-23)**: The information system shall protect the authenticity of communications sessions. This control addresses communications protection at the session level, versus packet level, and establishes grounds for confidence at both ends of communications sessions in ongoing identities of other parties and in the validity of information transmitted. Authenticity protection includes protecting against man-in-the-middle attacks, session hijacking, and the insertion of false information into sessions.
- Q. **Protection of Information at Rest (SC-28)**: The information system shall protect the Confidentiality and Integrity of user and system information at rest. Information at rest refers to the state of information when it is located on storage devices in specific components of information systems. System information requiring protection includes configurations or rule sets for Firewalls, Gateways, intrusion detection/prevention systems, filtering Routers, and authenticator content.

- R. **Process Isolation (SC-39):** The information system shall maintain a separate domain for each executing process. Information systems can maintain separate execution domains for each executing process by assigning each process a separate address space. Each information system process has a distinct address space so that one process cannot modify the executing code of another process and communication between processes is performed in a controlled manner through security functions. This capability is available in most commercial operating systems that employ multi-state processor technologies.
- S. **Exception Process:** To request an exception to one or more of the requirements outlined in this policy, please complete an IT Security Exception Request form.
1. The form is located within the IT Enterprise Services Portal under the “Services & Products” category.
 2. If you have any questions, please contact DAS OISP (refer to Section VII. Inquiries for contact information).

IV. Definitions

- A. **Boundary Protection Devices.** A device with appropriate mechanisms that: (i) facilitates the adjudication of different interconnected system security policies (e.g., controlling the flow of information into or out of an interconnected system); and/or (ii) provides information system boundary protection.¹
- B. **Confidentiality.** Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.²
- C. **DAS-Managed System Asset.** Information, hardware, software and services required to support state business, and identified during the risk assessment process as assets that need to be protected. Primary responsibility for managing these system assets may be assigned to DAS OIT personnel or other outside entities.
- D. **Denial of Service (DoS).** The prevention of authorized access to resources or the delaying of time-critical operations. (Time-critical may be milliseconds or it may be hours, depending upon the service provided.)³
- E. **Distributed Denial of Service (DDoS).** A Denial of Service technique that uses numerous hosts

¹ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

² *Ibid.*

³ Nieves, Michael, Kelley Dempsey, Victoria Yan Pillitteri. “NIST Special Publication 800-12 Revision 1, “An Introduction to Information Security,” U.S. Department of Commerce National Institute of Standards and Technology, June, 2017
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-12r1.pdf>>.

to perform the attack.⁴

- F. Firewall. A device or program that controls the flow of network traffic between networks or hosts that employ differing security postures.⁵
- G. Gateway. An intermediate system (interface, relay) that attaches to two (or more) computer networks that have similar functions but dissimilar implementations and that enables either one-way or two-way communication between the networks.⁶
- H. Information System Management Functionality. Functions necessary to administer databases, network components, workstations, or servers, and typically requires privileged user access.⁷
- I. Integrity. Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity.⁸
- J. Mobile Code. Software programs or parts of programs obtained from remote information systems, transmitted across a network, and executed on a local information system without explicit installation or execution by the recipient.⁹
- K. Protected Distribution Systems. Wire line or fiber optic system that includes adequate safeguards and/or countermeasures (e.g., acoustic, electric, electromagnetic, and physical) to permit its use for the transmission of unencrypted information through an area of lesser classification or control.¹⁰
- L. Public Key Infrastructure. The framework and services that provide for the generation, production, distribution, control, accounting, and destruction of public key certificates. Components include the personnel, policies, processes, server platforms, software, and workstations used for the purpose of administering certificates and public-private key pairs, including the ability to issue, maintain, recover, and revoke public key certificates.¹¹

⁴ “NISTIR 7711, Security Best Practices for the Electronic Transmission of Election Materials for UOCAVA Voters,” U.S. Department of Commerce National Institute of Standards and Technology, September 2011<<https://nvlpubs.nist.gov/nistpubs/Legacy/IR/nistir7711.pdf>>.

⁵ Scarfone, Karen, Paul Hoffman. “NIST Special Publication 800-41 Revision 1, Guidelines on Firewalls and Firewall Policy, Recommendations of the National Institute of Standards and Technology,” U.S. Department of Commerce National Institute of Standards and Technology, September 2009 <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-41r1.pdf>>.

⁶ Nieves, Michael, Kelley Dempsey, Victoria Yan Pillitteri. “NIST Special Publication 800-12 Revision 1, An Introduction to Information Security,” U.S. Department of Commerce National Institute of Standards and Technology, June, 2017 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-12r1.pdf>>.

⁷ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

⁸ *Ibid.*

⁹ *Ibid.*

¹⁰ *Ibid.*

¹¹ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

- M. Router. On a network, a device that determines the best path for forwarding a data packet toward its destination. The Router is connected to at least two networks, and is located at the Gateway where one network meets another.¹²
- N. Split Tunneling. A method that routes organization-specific traffic through the SSL VPN tunnel, but routes other traffic through the remote user's default Gateway.¹³
- O. Trust Anchors. A public or symmetric key that is trusted because it is directly built into hardware or software, or securely provisioned via out-of-band means, rather than because it is vouched for by another trusted entity (e.g. in a public key certificate). A trust anchor may have name or policy constraints limiting its scope.¹⁴
- P. Trust Stores. Organizations manage Trust Stores to ensure that only approved Trust Anchors are in such Trust Stores. This includes certificates with visibility external to organizational information systems and certificates related to the internal operations of systems.¹⁵
- Q. Voice over Internet Protocol. Voice over IP (VoIP, abbreviation of Voice over Internet Protocol) is a methodology and broad range of technologies for the delivery of voice communications and multimedia sessions over Internet Protocol (IP) networks, such as the Internet.

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Ohio IT Standard ITS-SEC-02 Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies

¹² Grance, Tim, Joan Hash, Steven Peck, Jonathan Smith, Karen Korow-Diks. "NIST Special Publication 800-47, "Security Guide for Interconnecting Information Technology Systems," U.S. Department of Commerce National Institute of Standards and Technology, August 2002 <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-47.pdf>>.

¹³ Frankel, Sheila, Paul Hoffman, Angela Orebaugh, Richard Park. "NIST Special Publication 800-113, "Guide to SSL VPNs, Recommendations of the National Institute of Standards and Technology," U.S. Department of Commerce National Institute of Standards and Technology, July 2008 <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-113.pdf>>.

¹⁴ Grassi, Paul A., Michael E. Garcia, James L. Fenton. "NIST Special Publication 800-63-3, Digital Identity Guidelines," U.S. Department of Commerce National Institute of Standards and Technology, June 2017 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-63-3.pdf>>.

¹⁵ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

Document Name	Location
DAS Standard DAS-ITS-2100-21-A Secure Active Content and Mobile Code	https://das.ohio.gov/technology-and-strategy/policies

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
01/15/2020	Original Policy.
08/02/2021	Conducted routine maintenance review of citations and references.
08/12/2021	Added a reference to DAS-ITS-2100-21-A Secure Active Content and Mobile Code Standard and updated the policy template.
03/05/2024	Updated the policy template. Added a revision history review frequency statement.